🔐 Laboratorio: Análisis de Colisiones Criptográficas — MD5 vs. SHA-256

> **Plataforma:** Kali Linux | **Fecha:** 23 de abril de 2026
> **Curso:** Criptología aplicada a la Ciberseguridad
> **Alumno:** Juan Zuñiga Carrasco | Informática — Ciberseguridad, 3er Semestre
> **Profesor:** Gerardo Calquin

📋 Resumen

Este laboratorio demuestra de forma práctica la inseguridad del algoritmo **MD5** mediante la identificación y verificación de colisiones criptográficas en Kali Linux. Se comprueba que dos archivos con contenido binario distinto pueden generar la misma firma digital (hash), validando la necesidad crítica de migrar a estándares robustos como **SHA-256** o **SHA-3**.

⚙️ Ambiente de Trabajo

Parámetro	Detalle
Sistema Operativo	Kali Linux
Directorio de trabajo	`~/lab_md5`
Archivos de prueba	`wang1.bin`, `wang2.bin`
Herramientas utilizadas	`md5sum`, `sha256sum`, `xxd`, `diff`, `openssl`, `Python 3`

Verificación de herramientas disponibles

```bash
which md5sum sha256sum xxd diff openssl python3
```

🧪 Pruebas Realizadas

1. Colisión MD5 — Verificación del fallo

```bash
```

```
md5sum wang1.bin wang2.bin
```

Resultado obtenido:

```
79054025255fb1a26e4bc422aef54eb4  wang1.bin
79054025255fb1a26e4bc422aef54eb4  wang2.bin
```

> ⚠️ **COLISIÓN DETECTADA:** Dos archivos con contenido binario distinto producen el **mismo hash MD5**.

---

2. Verificación SHA-256 — Confirmación de seguridad

```bash
sha256sum wang1.bin wang2.bin
```

Resultado obtenido:

```
8d12236e5c4ed9f4...  wang1.bin
b9fef2a8fc93b05e...  wang2.bin
```

> ✅ **SEGURO:** SHA-256 genera hashes completamente distintos para cada archivo, confirmando su integridad.

---

3. Análisis Hexadecimal — Confirmación de diferencias internas

```bash
diff <(xxd wang1.bin) <(xxd wang2.bin)
```

Los bloques marcados en rojo (`<`) corresponden a bytes de `wang1.bin` y los verdes (`>`) a `wang2.bin`. A pesar de que el hash MD5 es idéntico, la estructura binaria interna difiere en múltiples bloques, lo que confirma la manipulación matemática que fuerza la colisión.

📊 Tabla Comparativa de Resultados

Algoritmo	Hash wang1.bin	Hash wang2.bin	Re
MD5	`79054025255fb1a26e4bc422aef54eb4`	`79054025255fb1a26e4bc422aef54eb4`	🔴 CC
SHA-256	`8d12236e5c4ed9f4...`	`b9fef2a8fc93b05e...`	✅ SE

🛡️ Análisis de Riesgos

Tipo de Ataque	Descripción	Nivel de Impacto
Colisión de Hash	Dos archivos distintos con el mismo MD5 permiten evadir verificadores de integridad	🔴 CRÍTICO
Ataque de Diccionario	Uso de listas como `rockyou.txt` para revertir hashes por fuerza bruta	🟠 ALTO
Rainbow Tables	Bases de datos precalculadas para identificar la fuente de un hash MD5 en segundos	🟠 ALTO

✅ Conclusiones

- **MD5 está criptográficamente obsoleto.** No debe usarse para verificar integridad de software, firmas digitales ni contraseñas.
- **SHA-256 es el estándar vigente** recomendado por el NIST para todos los entornos de producción.
- **Un hash no garantiza autenticidad**, solo integridad. Para autenticidad se requiere firma criptográfica (HMAC-SHA256, RSA, ECDSA).
- El experimento reproduce con éxito colisiones MD5 documentadas en la literatura (paper de Xiaoyun Wang), validando los hallazgos en un entorno controlado.

📌 Recomendaciones

1. **Migrar a SHA-256 o SHA-3** en todos los procesos de verificación de integridad.
2. **Implementar firmas digitales** junto con el hash para garantizar autenticidad.
3. **Aplicar auditorías periódicas** sobre los algoritmos criptográficos en uso.
4. **Capacitar equipos** según los lineamientos del estándar **NIST SP 800-131A**.

📚 Referencias

#	Fuente	Descripción
1	NIST FIPS 186-4	Digital Signature Standard — algoritmos aprobados para firmas digitales
2	NIST SP 800-131A	Guía de transición para algoritmos criptográficos y longitudes de clave
3	RFC 1321	Especificación técnica original del algoritmo MD5 (IETF)
4	RFC 6234	Especificación SHA-1 y SHA-2 (IETF)
5	OWASP Cryptographic Storage Cheat Sheet	Buenas prácticas para almacenamiento seguro mediante criptografía
6	Schneier, Bruce — *Applied Cryptography*	Referencia fundamental sobre algoritmos criptográficos

---

Laboratorio práctico — Clase de Criptología aplicada a la Ciberseguridad